

PS02 – Politica de Seguridad de la Informacion

ID Documento: GOYA-PS02-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Uso Interno **Proximo revision:** 2027-09-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Oficial de Seguridad	Oficial de Seguridad de la Informacion
Revision tecnica	Arquitecto de Sistema	Arquitecto Criptografico / Sistema
Aprobacion	Pendiente	Gerente General

1.2 Distribucion

Este documento se clasifica como **Uso Interno** y se distribuye a todo el personal de Goya Ledger SpA, contratistas con acceso a sistemas del PSC, y proveedores con acceso a informacion clasificada. Cada receptor debe registrar acuse de recibo segun seccion 12.

1.3 Relacion con EA-103 v2.1

Esta politica cumple con el sub-proceso PS02 de la Guia de Acreditacion EA-103 v2.1 de la Entidad Acreditadora (Subsecretaria de Economia), y satisface los siete criterios de evaluacion de la seccion 4.9:

Criterio EA-103	Referencia en este documento
Conformidad con ISO 27002 seccion 5.1.1	Secciones 5, 6, 8
Procedimiento de revision y evaluacion periodica	Seccion 11
Coherencia entre politica de seguridad y CPS	Seccion 9
Coherencia entre politica de seguridad y CP	Seccion 9
Objetivos coherentes con niveles de riesgo de PS01	Seccion 5
Elementos fundamentales de una politica de seguridad	Secciones 2-8
Objetivos claros de proteccion de procesos, activos y servicios	Seccion 5

2. Declaracion de la Direccion

La Direccion de Goya Ledger SpA reconoce que la seguridad de la informacion es un requisito fundamental para operar como Prestador de Servicios de Certificacion (PSC) acreditado bajo la Ley 19.799.

La Direccion se compromete a:

1. Asegurar que la politica de seguridad de la informacion sea apropiada al proposito del PSC y proporcione un marco para establecer y revisar los objetivos de seguridad.
2. Asignar los recursos humanos, tecnologicos y financieros necesarios para implementar, mantener y mejorar continuamente los controles de seguridad.
3. Cumplir con los requisitos legales, regulatorios y contractuales aplicables a los servicios de certificacion, incluyendo la Ley 19.799, DS 181/2002, Ley 19.628 y Ley 21.459.
4. Gestionar los riesgos de seguridad de la informacion de acuerdo con el Plan de Gestion de Riesgos (PS01, GOYA-PS01-001).
5. Exigir a todo el personal, contratistas y terceros con acceso a sistemas del PSC el cumplimiento de esta politica.
6. Someter esta politica a revision periodica para asegurar su adecuacion y eficacia continua.

Firma:

Nombre: _____

Cargo: Gerente General, Goya Ledger SpA

Fecha: _____

Firma: _____

3. Objetivo y Alcance

3.1 Objetivo

Definir la política de seguridad de la información de Goya Ledger SpA en su calidad de PSC acreditado, estableciendo los principios, responsabilidades y directrices que protegen la confidencialidad, integridad y disponibilidad de los activos de información del PSC y de los datos de sus suscriptores.

3.2 Servicios cubiertos

Esta política aplica a la totalidad de los servicios de confianza prestados por Goya Ledger:

Servicio	Descripción	Norma técnica principal
Autoridad Certificadora (CA)	Emisión, gestión y revocación de certificados X.509 para Firma Electrónica Avanzada (FEA)	Ley 19.799 Art. 17, DS 181, D.S. 24/2019
Autoridad de Sellado de Tiempo (TSA)	Emisión de sellos de tiempo calificados	RFC 3161, ETSI EN 319 422
Respondedor OCSP	Consultas de estado de certificados en tiempo real	RFC 6960, ETSI EN 319 411-2
Autoridad de Registro (RA)	Verificación de identidad presencial y remota de solicitantes	DS 181 Art. 13, ETSI EN 319 411-1

3.3 Aplicabilidad

Esta política aplica a:

- Todo el personal permanente de Goya Ledger SpA, independiente de su cargo o función.
- Contratistas, consultores y personal temporal con acceso a sistemas, instalaciones o información del PSC.
- Proveedores de servicios con acceso a datos o infraestructura del PSC (Fly.io, proveedores de HSM, fuentes de identidad).
- Los activos criptográficos, de datos, de infraestructura e intangibles catalogados en PS01 secciones 3.1 a 3.4.

3.4 Exclusiones

No se identifican exclusiones al alcance. Todos los sistemas, procesos y datos involucrados en la operacion del PSC estan sujetos a esta politica.

4. Marco Normativo y Legal

4.1 Legislacion chilena

Norma	Descripcion	Aplicacion al PSC
Ley 19.799 (2002)	Documentos electronicos, firma electronica y servicios de certificacion	Marco juridico para la operacion del PSC y la emision de certificados FEA
DS 181/2002	Reglamento de la Ley 19.799	Requisitos operativos, de seguridad y de auditoria para PSC acreditados
Ley 19.628 (1999)	Proteccion de la vida privada (datos personales)	Tratamiento de datos personales de suscriptores (RUT, nombre, datos biometricos)
Ley 21.459 (2022)	Delitos informaticos	Tipificacion de delitos relevantes: acceso ilicito, interceptacion, dano informatico
D.S. N 24/2019	Norma tecnica para FEA	Requisitos tecnicos para certificados FEA, algoritmos aprobados, perfiles de certificado

4.2 Normas y guias de acreditacion

Norma	Descripcion	Aplicacion al PSC
EA-103 v2.1	Guia de acreditacion de PSC (Subsecretaria de Economia)	Procesos de evaluacion PS01-PS07, SF01, PE01-PE02
ISO/IEC 27001:2022	Sistema de gestion de seguridad de la informacion	Clausula 5.2 (politica), Clausula 6 (planificacion), Clausula 8 (operacion)
ISO/IEC 27002:2022	Controles de seguridad de la informacion	93 controles en 4 temas, referenciados en seccion 8
ETSI EN 319 401	Requisitos generales para prestadores de servicios de confianza	Requisitos de gestion, politica y seguridad para TSP
ETSI EN 319 411-1	Requisitos de politica para CA que emiten certificados no cualificados	Perfil de politica para CA
ETSI EN 319 411-2		Perfil de politica para CA que emite FEA

Norma	Descripcion	Aplicacion al PSC
	Requisitos de politica para CA que emiten certificados cualificados	
ETSI EN 319 421	Requisitos de politica y seguridad para TSA	Requisitos de seguridad para el servicio de sellado de tiempo

4.3 Normas tecnicas

Norma	Descripcion	Aplicacion al PSC
FIPS 204 (2024)	ML-DSA (Module-Lattice-Based Digital Signature Algorithm)	Algoritmo de firma para certificados FEA (ML-DSA-65, nivel NIST 3)
FIPS 186-5 (2023)	Digital Signature Standard	Ed25519 para Firma Electronica Simple (FES)
NIST SP 800-57 Parte 1	Gestion de claves criptograficas	Ciclo de vida de claves CA, TSA, OCSP y suscriptores
RFC 3647	Estructura de CP/CPS	Estructura del CPS de Goya Ledger (ver docs/policy/CPS.md)

5. Objetivos de Seguridad

Los objetivos de seguridad se derivan del analisis de riesgos documentado en PS01 (GOYA-PS01-001) y estan alineados con los procesos de negocio del PSC. Cada objetivo responde a uno o mas riesgos catalogados con nivel Medio o superior.

5.1 Objetivos estrategicos

ID	Objetivo	Riesgos PS01 asociados	KPI	Meta
OS-01	Proteger la confidencialidad e integridad de las claves privadas del PSC (CA, TSA, OCSP) durante todo su ciclo de vida	R-01, R-02, R-05	Incidentes de compromiso de clave por periodo	0 incidentes/ano
OS-02	Garantizar la disponibilidad de los servicios de certificacion, sellado de tiempo y	R-04, R-07, R-21	Disponibilidad mensual de servicios CA, TSA y OCSP	>= 99.5%

ID	Objetivo	Riesgos PS01 asociados	KPI	Meta
OS-03	consulta de estado conforme a los SLA publicados Asegurar la precision temporal del servicio TSA dentro de la tolerancia definida respecto a UTC	R-07	Desviacion maxima respecto a UTC	≤ 1 segundo
OS-04	Verificar la identidad de cada solicitante de certificado FEA conforme a DS 181 y D.S. 24/2019	R-06, R-28	Tasa de error en verificacion de identidad detectada en auditoria	$< 0.5\%$
OS-05	Mantener la integridad y completitud de los registros de auditoria del PSC	R-19, R-27	Verificaciones de integridad de cadena hash fallidas	0 fallas/ trimestre
OS-06	Proteger los datos personales de suscriptores conforme a la Ley 19.628	R-26, R-35	Incidentes de fuga o acceso no autorizado a datos personales	0 incidentes/ ano
OS-07	Mantener la resiliencia criptografica del PSC frente a amenazas cuanticas y classicas	R-10, R-11, R-12, R-13	Porcentaje de certificados FEA emitidos con ML-DSA-65	100% de FEA
OS-08	Prevenir la emision no autorizada de certificados por personal interno	R-05, R-06	Emisiones de certificados fuera de flujo RA autorizado	0 emisiones/ ano
OS-09	Asegurar la integridad de la cadena de suministro de software del PSC	R-15, R-23	Vulnerabilidades criticas en dependencias sin parche > 30 dias	0
OS-10		R-21, R-22		

ID	Objetivo	Riesgos PS01 asociados	KPI	Meta
	Mantener la capacidad de recuperacion ante desastres conforme al plan de continuidad		Tiempo de recuperacion en simulacro	RTO <= 4 horas

5.2 Revision de objetivos

Los objetivos de seguridad y sus KPIs se revisan semestralmente por el Oficial de Seguridad y se presentan a la Gerencia General para validacion. La revision verifica:

- Cumplimiento de metas KPI en el periodo anterior.
- Cambios en el perfil de riesgo identificados en PS01.
- Nuevas amenazas o vulnerabilidades relevantes.
- Resultados de auditorias internas y externas.

6. Principios de Seguridad

La politica de seguridad de Goya Ledger se fundamenta en los siguientes principios, aplicables a todos los servicios y procesos del PSC.

6.1 Confidencialidad

La informacion del PSC se clasifica y protege segun su nivel de sensibilidad. Solo el personal autorizado accede a informacion clasificada, y unicamente en la medida necesaria para el desempeno de sus funciones. Las claves privadas del PSC constituyen el activo de maxima confidencialidad.

6.2 Integridad

Los datos del PSC se protegen contra modificacion o destruccion no autorizada. Los registros de auditoria emplean cadenas hash para garantizar integridad verificable. Los certificados y sellos de tiempo se firman criptograficamente para asegurar su autenticidad.

6.3 Disponibilidad

Los servicios del PSC se mantienen operativos conforme a los SLA publicados. Los mecanismos de redundancia, respaldo y recuperacion aseguran la continuidad ante fallas de componentes individuales.

6.4 Minimo privilegio

Cada usuario, proceso y sistema recibe exclusivamente los permisos minimos necesarios para cumplir su funcion. Los accesos se conceden de forma explicita y se revocan al cesar la necesidad.

6.5 Defensa en profundidad

La proteccion de activos criticos se implementa en multiples capas complementarias. La falla de un control individual no compromete la seguridad del activo protegido. Los controles operan a nivel de red, sistema, aplicacion y procedimiento.

6.6 Segregacion de funciones

Las funciones criticas del PSC requieren la participacion de mas de una persona. El administrador de sistemas no opera la CA. El operador de la CA no aprueba solicitudes de certificados. La auditoria es independiente de las operaciones.

6.7 No repudio

Las acciones criticas del PSC se registran con identidad verificable del ejecutante, marca de tiempo y detalle de la operacion. La evidencia de auditoria permite reconstruir la secuencia de eventos y atribuir responsabilidad.

7. Roles y Responsabilidades

7.1 Gerencia General

- Aprobar esta politica y sus actualizaciones.
- Asignar los recursos necesarios para la implementacion de los controles de seguridad.
- Designar al Oficial de Seguridad de la Informacion.
- Revisar los informes semestrales de estado de seguridad.
- Asumir la responsabilidad final sobre la seguridad de la informacion del PSC ante la Entidad Acreditadora.

7.2 Oficial de Seguridad de la Informacion

- Elaborar, mantener y difundir las politicas de seguridad del PSC.
- Coordinar la ejecucion del Plan de Gestion de Riesgos (PS01).
- Supervisar la implementacion de los controles de seguridad.
- Gestionar los incidentes de seguridad conforme al Plan de Respuesta a Incidentes (PS07, GOYA-IRP-001).
- Coordinar las auditorias internas y externas de seguridad.
- Reportar semestralmente a la Gerencia General sobre el estado de seguridad y cumplimiento de KPIs.
- Mantener el programa de concientizacion en seguridad.

- Autorizar excepciones temporales a esta politica con registro documentado.

7.3 Administrador de la Autoridad Certificadora

- Operar la CA conforme al CPS (OID 1.3.6.1.4.1.99999.2.2) y a esta politica.
- Ejecutar procedimientos de emision, renovacion, suspension y revocacion de certificados.
- Custodiar las claves privadas de la CA intermedia durante la operacion.
- Participar en ceremonias de claves de la CA raiz conforme al procedimiento documentado.
- Publicar CRL y mantener el respondedor OCSP operativo.
- Reportar inmediatamente al Oficial de Seguridad cualquier anomalia en la operacion de la CA.

7.4 Administrador de la Autoridad de Registro

- Ejecutar los procedimientos de verificacion de identidad de solicitantes de certificados.
- Aprobar o rechazar solicitudes de certificados conforme a DS 181 Art. 13 y D.S. 24/2019.
- Custodiar la documentacion probatoria de identidad de los suscriptores.
- Mantener la confidencialidad de los datos personales de solicitantes conforme a Ley 19.628.
- Registrar cada verificacion de identidad en el log de auditoria.

7.5 Personal tecnico

- Administrar la infraestructura de servidores, redes y almacenamiento del PSC.
- Aplicar parches de seguridad y actualizaciones dentro de los plazos definidos.
- Monitorear la disponibilidad y rendimiento de los servicios.
- Ejecutar respaldos conforme al procedimiento documentado.
- Reportar al Oficial de Seguridad cualquier evento de seguridad detectado.

7.6 Auditoria interna

- Verificar el cumplimiento de esta politica y de los procedimientos derivados.
 - Ejecutar auditorias planificadas conforme al programa anual de auditoria.
 - Reportar hallazgos a la Gerencia General y al Oficial de Seguridad.
 - Verificar la implementacion de acciones correctivas.
 - Operar con independencia funcional respecto a las areas auditadas.
-

8. Politicas Especificas por Dominio

Cada dominio de seguridad se rige por directrices derivadas de esta politica general. Los controles referenciados corresponden a ISO/IEC 27002:2022. Las politicas detalladas y procedimientos operativos se documentan en los documentos complementarios indicados.

8.1 Control de acceso

Controles ISO 27002:2022: 5.15 (Control de acceso), 5.16 (Gestion de identidades), 5.17 (Informacion de autentificacion), 5.18 (Derechos de acceso), 8.2 (Derechos de acceso privilegiado), 8.3 (Restriccion de acceso a informacion), 8.4 (Acceso a codigo fuente), 8.5 (Autenticacion segura).

Directrices:

- El acceso a los sistemas del PSC se otorga bajo el principio de minimo privilegio y se revoca al cesar la necesidad.
- El acceso administrativo a nodos BFT, CA, TSA y OCSP requiere autentificacion por clave publica (SSH) restringida a direcciones IP autorizadas.
- Las operaciones criticas de la CA (emision, revocacion) requieren autentificacion de doble factor.
- Los derechos de acceso se revisan trimestralmente por el Oficial de Seguridad.
- El acceso al codigo fuente del PSC se restringe al personal tecnico autorizado mediante control de acceso del repositorio.
- El sistema implementa ACL deny-by-default (ACL_MODE) con roles diferenciados por endpoint conforme a `enforce_acl`.

8.2 Criptografia y gestion de claves

Controles ISO 27002:2022: 8.24 (Uso de criptografia).

Referencia complementaria: PS06 (Gestion de Claves Criptograficas).

Directrices:

- Los certificados FEA se firman exclusivamente con ML-DSA-65 (FIPS 204, nivel de seguridad NIST 3), clasificado como “recommended” por BSI TR-02102-1 (2024).
- Las firmas electronicas simples (FES) utilizan Ed25519 (FIPS 186-5), clasificado como “transitional” por BSI TR-02102-1.
- El despliegue PQC emplea modo hibrido obligatorio (firma clasica + firma post-cuantica simultaneas) conforme a la recomendacion ANSSI “Avis relatif a la migration vers la cryptographie post-quantique” (2024, seccion 2): la seguridad no debe depender exclusivamente de un algoritmo post-cuantico ni exclusivamente de uno clasico. El modo hibrido combina supuestos matematicos independientes (ECC + lattice).
- Las claves privadas de la CA raiz se almacenan offline, fragmentadas mediante esquema M-of-N, y solo se activan durante ceremonias de clave documentadas.
- Las claves privadas de la CA intermedia, TSA y OCSP se protegen mediante HSM certificado FIPS 140-3 Nivel 2 o superior (en proceso de implementacion; interim: almacenamiento en memoria volatil del servidor con zeroizacion al terminar).
- La generacion, almacenamiento, uso, rotacion, respaldo, recuperacion y destruccion de claves siguen el ciclo de vida definido en NIST SP 800-57 Parte 1.
- Las comunicaciones entre nodos BFT emplean TLS 1.3 con mutual TLS obligatorio.
- Los sellos de tiempo TSA emplean el algoritmo de firma configurado en la CA.
- El modulo criptografico central (`crates/pqc_crypto_module/`) es la unica fuente autorizada de operaciones criptograficas. Las importaciones directas de

primitivas criptograficas en el codigo fuente principal estan prohibidas (verificado por cargo test --test crypto_boundary).

8.3 Seguridad fisica

Controles ISO 27002:2022: 7.1 (Perimetros de seguridad fisica), 7.2 (Controles de entrada fisica), 7.3 (Seguridad de oficinas), 7.4 (Vigilancia de seguridad fisica), 7.5 (Proteccion contra amenazas fisicas), 7.6 (Trabajo en areas seguras), 7.7 (Escritorio limpio y pantalla limpia), 7.8 (Ubicacion y proteccion de equipos), 7.9 (Seguridad de activos fuera de las instalaciones), 7.10 (Medios de almacenamiento), 7.11 (Servicios de soporte), 7.12 (Seguridad del cableado), 7.13 (Mantenimiento de equipos), 7.14 (Eliminacion o reutilizacion segura de equipos).

Referencia complementaria: SF01 (Seguridad Fisica).

Directrices:

- La infraestructura de produccion opera en datacenters Fly.io (region IAD) con controles fisicos gestionados por el proveedor cloud, verificados conforme a los reportes SOC 2 del proveedor.
- Los medios fisicos que contengan claves criptograficas o fragmentos M-of-N se almacenan en ubicaciones seguras independientes con control de acceso registrado.
- Los equipos utilizados para ceremonias de clave de la CA raiz operan sin conexion a red y se almacenan bajo custodia controlada.
- La destruccion de medios de almacenamiento que contengan claves o datos sensibles sigue procedimientos documentados de borrado seguro.

8.4 Seguridad de operaciones

Controles ISO 27002:2022: 8.1 (Dispositivos de punto final de usuario), 8.6 (Gestion de capacidad), 8.7 (Proteccion contra software malicioso), 8.8 (Gestion de vulnerabilidades tecnicas), 8.9 (Gestion de configuracion), 8.10 (Eliminacion de informacion), 8.13 (Respaldo de informacion), 8.14 (Redundancia de instalaciones de procesamiento), 8.15 (Registro de eventos), 8.16 (Monitoreo de actividades), 8.17 (Sincronizacion de relojes), 8.19 (Instalacion de software en sistemas en produccion), 8.25 (Ciclo de vida de desarrollo seguro), 8.28 (Codificacion segura), 8.29 (Pruebas de seguridad en desarrollo y aceptacion), 8.31 (Separacion de ambientes de desarrollo, prueba y produccion), 8.32 (Gestion de cambios), 8.33 (Informacion de prueba), 8.34 (Proteccion de sistemas de informacion durante pruebas de auditoria).

Directrices:

- Los cambios en sistemas de produccion siguen un proceso de gestion de cambios documentado con revision de codigo, pruebas automatizadas y aprobacion explicita antes del despliegue.
- El pipeline de integracion continua ejecuta: cargo fmt --check, cargo clippy -- -D warnings, cargo test --lib, y cargo test --test crypto_boundary en cada cambio.
- Los ambientes de desarrollo, prueba y produccion estan separados. El ambiente de produccion no se utiliza para pruebas.

- Los respaldos de RocksDB se ejecutan conforme al procedimiento documentado con verificación de integridad y almacenamiento off-site.
- Los relojes de todos los nodos del PSC se sincronizan con fuentes NTP independientes con verificación de desviación (tolerancia máxima: 1 segundo respecto a UTC).
- Los registros de eventos del PSC se almacenan en cadena hash SHA-256 append-only para garantizar integridad verificable.
- Las vulnerabilidades en dependencias se detectan mediante cargo-audit y se remedian conforme a los plazos definidos: críticas en 72 horas, altas en 7 días, medias en 30 días.
- La gestión de capacidad monitorea el uso de almacenamiento, CPU y memoria de los nodos BFT con alertas ante umbrales críticos.

8.5 Seguridad de comunicaciones

Controles ISO 27002:2022: 8.20 (Seguridad de redes), 8.21 (Seguridad de servicios de red), 8.22 (Segregación de redes), 8.23 (Filtrado web).

Directrices:

- Las comunicaciones entre nodos BFT emplean TCP con mutual TLS 1.3 obligatorio.
- La API Gateway expuesta a internet opera sobre TLS 1.3. En ambiente de producción (RUST_BC_ENV=production), los certificados TLS son obligatorios (TLS_CERT_PATH, TLS_KEY_PATH).
- La red P2P entre nodos BFT opera en segmento de red privado. Solo la API Gateway está expuesta a tráfico externo.
- Los mensajes del protocolo gossip incluyen firma criptográfica verificada antes de su procesamiento.
- Los orígenes CORS permitidos se configuran explícitamente (CORS_ALLOWED_ORIGINS); no se permite wildcard en producción.

8.6 Gestión de incidentes de seguridad

Controles ISO 27002:2022: 5.24 (Planificación y preparación de gestión de incidentes), 5.25 (Evaluación y decisión sobre eventos de seguridad), 5.26 (Respuesta a incidentes), 5.27 (Aprendizaje de incidentes), 5.28 (Recopilación de evidencia).

Referencia complementaria: PS07 (Plan de Respuesta a Incidentes, GOYA-IRP-001).

Directrices:

- Todos los eventos de seguridad se reportan al Oficial de Seguridad conforme al procedimiento del Plan de Respuesta a Incidentes.
- Los incidentes se clasifican en cuatro niveles de severidad (P1 a P4) con tiempos de respuesta definidos: P1 (Crítico) menos de 1 hora, P2 (Alto) menos de 4 horas, P3 (Medio) menos de 24 horas, P4 (Bajo) menos de 72 horas.
- Los incidentes P1 (compromiso de clave CA, emisión fraudulenta masiva) se escalan a la Entidad Acreditadora conforme a DS 181.
- La evidencia de incidentes se preserva conforme al procedimiento de recopilación de evidencia documentado.

- Cada incidente cerrado genera un informe post-mortem con lecciones aprendidas y acciones correctivas.

8.7 Continuidad del negocio

Controles ISO 27002:2022: 5.29 (Seguridad de la información durante interrupción), 5.30 (Preparación de TIC para continuidad del negocio).

Referencia complementaria: PS03 (Plan de Continuidad del Negocio y Recuperación ante Desastres).

Directrices:

- El PSC mantiene un plan de continuidad del negocio y recuperación ante desastres documentado y probado.
- El objetivo de tiempo de recuperación (RTO) para los servicios críticos (CA, TSA, OSCP) es de 4 horas.
- El objetivo de punto de recuperación (RPO) es de 1 hora para datos transaccionales.
- El consenso BFT tolera la falla de hasta f nodos en una red de $3f+1$, proporcionando redundancia nativa.
- Los simulacros de recuperación se ejecutan semestralmente con registro de resultados y acciones de mejora.

8.8 Cumplimiento legal y regulatorio

Controles ISO 27002:2022: 5.31 (Requisitos legales, regulatorios y contractuales), 5.32 (Derechos de propiedad intelectual), 5.33 (Protección de registros), 5.34 (Privacidad y protección de PII), 5.35 (Revisión independiente de seguridad de la información), 5.36 (Cumplimiento con políticas, reglas y estándares de seguridad de la información).

Directrices:

- El PSC cumple con la legislación chilena aplicable identificada en la sección 4.1.
- Los datos personales de suscriptores (nombre, RUT, correo, datos biométricos) se tratan conforme a la Ley 19.628 con consentimiento informado, finalidad específica y plazo de retención definido.
- Los registros de auditoría se conservan por un período mínimo de 6 años conforme a DS 181.
- Se ejecutan revisiones independientes de seguridad al menos una vez al año o ante cambios significativos en la infraestructura o servicios del PSC.
- El cumplimiento de esta política se verifica mediante auditorías internas semestrales y auditorías externas anuales.

8.9 Seguridad del personal

Controles ISO 27002:2022: 6.1 (Selección), 6.2 (Términos y condiciones de empleo), 6.3 (Concientización, educación y formación en seguridad), 6.4 (Proceso disciplinario), 6.5 (Responsabilidades después del término o cambio de empleo), 6.6 (Acuerdos de confidencialidad o no divulgación), 6.7 (Trabajo remoto), 6.8 (Reportes de eventos de seguridad de la información).

Referencia complementaria: PE01 (Plan de Dotación de Personal y Capacitación), PE02 (Evaluación de Competencias).

Directrices:

- El personal con acceso a sistemas críticos del PSC (CA, HSM, registros de auditoría) se somete a verificación de antecedentes antes de otorgar acceso.
- Todos los empleados y contratistas firman acuerdos de confidencialidad y no divulgación que cubren las obligaciones durante y después de la relación laboral.
- El programa de concientización en seguridad se ejecuta anualmente e incluye: política de seguridad, manejo de información clasificada, reporte de incidentes, prevención de ingeniería social.
- Al término de la relación laboral, se revocan todos los accesos dentro de las 24 horas siguientes y se recuperan los activos del PSC asignados.
- Los eventos de seguridad observados por cualquier persona se reportan al Oficial de Seguridad sin demora.

8.10 Gestión de activos

Controles ISO 27002:2022: 5.9 (Inventario de información y otros activos asociados), 5.10 (Uso aceptable de información y otros activos asociados), 5.11 (Devolución de activos), 5.12 (Clasificación de información), 5.13 (Etiquetado de información), 5.14 (Transferencia de información).

Directrices:

- El inventario de activos del PSC se mantiene actualizado conforme a PS01 secciones 3.1 a 3.4 e incluye: activos criptográficos, activos de datos, activos de infraestructura y activos intangibles.
 - La información se clasifica en cuatro niveles: Pública, Uso Interno, Confidencial, Estrictamente Confidencial.
 - Los activos criptográficos (claves privadas CA, TSA, OCSP, suscriptores) se clasifican como Estrictamente Confidencial o Confidencial según su criticidad.
 - La transferencia de información clasificada se realiza exclusivamente por canales cifrados y con registro de remitente, destinatario y contenido.
 - Al cesar la necesidad de uso, los activos del PSC asignados a personal se devuelven conforme al procedimiento de devolución documentado.
-

9. Coherencia con CPS y CP

9.1 Referencia cruzada con CPS

La presente politica de seguridad es coherente con el Certification Practice Statement de Goya Ledger (OID 1.3.6.1.4.1.99999.2.2, version 1.0.0, documentado en docs/policy/CPS.md). La siguiente tabla verifica la alineacion:

Aspecto	Seccion CPS	Seccion PS02	Verificacion de coherencia
Algoritmos de firma	CPS 6 (Technical Security Controls)	8.2	ML-DSA-65 para FEA, Ed25519 para FES. Coherente.
Control de acceso a la CA	CPS 5 (Facility, Management, and Operational Controls)	8.1	ACL deny-by-default, autenticacion por clave publica. Coherente.
Proteccion de claves CA	CPS 6 (Technical Security Controls)	8.2	CA raiz offline M-of-N, CA intermedia en HSM/servidor. Coherente.
Registro de auditoria	CPS 5 (Facility, Management, and Operational Controls)	8.4	Cadena hash SHA-256 append-only. Coherente.
Verificacion de identidad	CPS 3 (Identification and Authentication)	8.1, OS-04	Smart-ID, ClaveUnica, verificacion documental. Coherente.
Revocacion y OSCP	CPS 4 (Certificate Life-Cycle), CPS 7 (Profiles)	8.4, OS-02	RFC 6960, disponibilidad conforme a SLA. Coherente.
Sellado de tiempo	CPS referencia TSA	8.4, OS-03	RFC 3161, tolerancia NTP <= 1 segundo. Coherente.
Respuesta a incidentes	CPS 5	8.6	Plan de Respuesta a Incidentes GOYA-IRP-001. Coherente.

9.2 Referencia cruzada con CP

La Política de Certificados (CP, OID 1.3.6.1.4.1.99999.2.1) establece los requisitos de política que el CPS implementa. Esta política de seguridad opera como marco transversal que sustenta ambos documentos. Los niveles de aseguramiento definidos en la CP para certificados FEA se reflejan en los controles de esta política (segregación de funciones, autenticación dual, protección de claves).

9.3 Procedimiento de verificación de coherencia

En cada revisión de esta política (sección 11), el Oficial de Seguridad verifica que:

1. Los controles de seguridad referenciados en el CPS no contradicen las directrices de esta política.
 2. Los algoritmos y longitudes de clave permitidos en esta política coinciden con los declarados en el CPS y la CP.
 3. Los roles y responsabilidades definidos en esta política son compatibles con los declarados en el CPS sección 5.
 4. Las modificaciones a cualquiera de los tres documentos se evalúan por impacto cruzado antes de su aprobación.
-

10. Sanciones por Incumplimiento

10.1 Alcance

Todo el personal, contratistas y terceros sujetos a esta política (sección 3.3) son responsables de su cumplimiento. El desconocimiento de la política no constituye eximente.

10.2 Clasificación de infracciones

Categoría	Ejemplos	Consecuencia
Leve	Omision de reporte de evento de seguridad, incumplimiento de política de escritorio limpio	Amonestacion verbal. Capacitacion correctiva.
Grave	Compartir credenciales de acceso, acceder a informacion sin autorizacion, omitir procedimiento de verificacion de identidad en RA	Amonestacion escrita. Suspension temporal de accesos. Capacitacion obligatoria.
Muy grave	Compromiso deliberado de claves criptograficas,	Desvinculacion inmediata. Denuncia ante autoridades conforme a Ley 21.459.

Categoría	Ejemplos	Consecuencia
	exfiltración de datos de suscriptores, emisión fraudulenta de certificados, sabotaje de registros de auditoría	Notificación a la Entidad Acreditadora.

10.3 Proceso disciplinario

1. El Oficial de Seguridad documenta la infracción con evidencia.
2. Se notifica al infractor y se le otorga oportunidad de descargo.
3. El Oficial de Seguridad propone la sanción a la Gerencia General.
4. La Gerencia General resuelve y notifica la sanción al infractor.
5. Se registra la sanción y las acciones correctivas adoptadas.
6. Para infracciones muy graves, se inicia el proceso legal correspondiente de forma paralela.

11. Revision y Mantencion

11.1 Revision periodica

Esta política se revisa como mínimo una vez al año. La próxima revisión programada es el **2027-09-01**.

11.2 Revision por evento

Además de la revisión anual, esta política se revisa dentro de los 30 días siguientes a cualquiera de estos eventos:

- Incidente de seguridad clasificado como P1 (Crítico) o P2 (Alto).
- Cambio en la legislación o regulación aplicable (Ley 19.799, DS 181, Ley 19.628, Ley 21.459, D.S. 24/2019).
- Resultado de auditoría interna o externa con hallazgos que afecten la política.
- Cambio significativo en la infraestructura, servicios o arquitectura del PSC.
- Modificación del perfil de riesgo identificada en la revisión de PS01.
- Cambio en los algoritmos criptográficos aprobados o en las guías del NIST/ETSI.

11.3 Responsable de la revision

El Oficial de Seguridad de la Información es responsable de:

- Iniciar el proceso de revisión en las fechas programadas o ante eventos disparadores.
- Coordinar la revisión técnica con el Arquitecto de Sistema y el Administrador de la CA.
- Verificar la coherencia con CPS y CP conforme a sección 9.3.

- Someter la version revisada a aprobacion de la Gerencia General.
- Registrar los cambios en la tabla de control de versiones (seccion 1).

11.4 Registro de revisiones

Cada revision se registra en la tabla de control del documento al inicio de este archivo. El registro incluye: version, fecha, autor y descripcion de los cambios realizados.

12. Comunicacion y Difusion

12.1 Distribucion inicial

Al aprobarse esta politica, el Oficial de Seguridad la distribuye a todo el personal comprendido en el alcance (seccion 3.3) mediante los siguientes mecanismos:

- Correo electronico con copia de la politica y solicitud de acuse de recibo.
- Publicacion en el repositorio interno del PSC.
- Sesion informativa presencial o remota para el personal.

12.2 Acuse de recibo

Cada persona que recibe esta politica debe firmar un acuse de recibo que declara:

- Haber leído y comprendido la politica en su totalidad.
- Comprometerse a cumplir las directrices y procedimientos establecidos.
- Comprender las consecuencias por incumplimiento (seccion 10).

Los acuses de recibo se conservan por el Oficial de Seguridad durante el periodo de relacion laboral o contractual y un minimo de 2 anos posteriores.

12.3 Actualizaciones

Cada actualizacion de esta politica se comunica al personal afectado dentro de los 15 dias habiles siguientes a su aprobacion, con identificacion explicita de los cambios respecto a la version anterior.

12.4 Programa de concientizacion

El Oficial de Seguridad mantiene un programa anual de concientizacion en seguridad de la informacion que incluye:

- Induccion en seguridad para personal nuevo (dentro de la primera semana).
 - Capacitacion anual en: politica de seguridad vigente, prevencion de ingenieria social, manejo de incidentes, proteccion de datos personales.
 - Simulacros de phishing semestrales con medicion de resultados.
 - Actualizaciones sobre amenazas emergentes relevantes para el PSC.
-

13. Referencias

13.1 Documentos internos del PSC

Documento	ID / Ubicacion	Relacion
PS01 – Plan de Gestion de Riesgos y Amenazas	GOYA-PS01-001, docs/compliance/PS01-RISK-MANAGEMENT-PLAN.md	Base para objetivos de seguridad (seccion 5)
PS03 – Plan de Continuidad del Negocio	docs/compliance/BUSINESS-CONTINUITY-DR.md	Referenciado en seccion 8.7
PS06 – Gestion de Claves Criptograficas	Pendiente de elaboracion	Referenciado en seccion 8.2
PS07 – Plan de Respuesta a Incidentes	GOYA-IRP-001, docs/compliance/INCIDENT-RESPONSE-PLAN.md	Referenciado en seccion 8.6
SF01 – Seguridad Fisica	docs/compliance/PHYSICAL-SECURITY.md	Referenciado en seccion 8.3
PE01 – Plan de Dotacion de Personal	Pendiente de elaboracion	Referenciado en seccion 8.9
PE02 – Evaluacion de Competencias	Pendiente de elaboracion	Referenciado en seccion 8.9
CPS – Certification Practice Statement	OID 1.3.6.1.4.1.99999.2.2, docs/policy/CPS.md	Referenciado en seccion 9
CP – Politica de Certificados	OID 1.3.6.1.4.1.99999.2.1	Referenciado en seccion 9
Marco de Cumplimiento	docs/compliance/COMPLIANCE-FRAMEWORK.md	Mapeo de controles ISO 27001/SOC 2

13.2 Normativa externa

Norma	Referencia
Ley 19.799	Ley sobre documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002	Reglamento de la Ley 19.799
D.S. N 24/2019	Norma tecnica para la Firma Electronica Avanzada
Ley 19.628	Ley sobre proteccion de la vida privada
Ley 21.459	Ley de delitos informaticos
EA-103 v2.1	Guia de acreditacion de PSC
ISO/IEC 27001:2022	Sistemas de gestion de seguridad de la informacion
ISO/IEC 27002:2022	Controles de seguridad de la informacion
ETSI EN 319 401	Requisitos generales para prestadores de servicios de confianza

Norma	Referencia
ETSI EN 319 411-1	Requisitos de politica para CA (no cualificados)
ETSI EN 319 411-2	Requisitos de politica para CA (cualificados)
ETSI EN 319 421	Requisitos de politica y seguridad para TSA
FIPS 204	ML-DSA (Module-Lattice-Based Digital Signature Algorithm)
BSI TR-02102-1 (2024)	Kryptographische Verfahren: Empfehlungen und Schlüssellängen (Algoritmos criptograficos: recomendaciones y longitudes de clave)
ANSSI Avis PQC (2024)	Avis relatif a la migration vers la cryptographie post-quantique (Recomendacion sobre migracion a criptografia post-cuantica)
FIPS 186-5	Digital Signature Standard (Ed25519)
NIST SP 800-57 Parte 1	Gestion de claves criptograficas
RFC 3161	Internet X.509 PKI Time-Stamp Protocol
RFC 3647	Internet X.509 PKI Certificate Policy and CPS Framework
RFC 6960	X.509 Internet PKI OCSP